HUTECH
Đại học Công nghệ Tp.HCM

THIẾT KẾ VÀ ĐÁNH GIÁ HỆ THỐNG BẢO MẬT MẠNG DOANH NGHIỆP SỬ DỤNG FIREWALL (PFSENSE).

GVHD: ThS. Văn Thiên hoàng

Trần Tăng Trường Thịnh 2387701939

HUTECH
Đại học Công nghệ Tp.HCM

MỤC LỤC

- GIỚI THIỆU
- CƠ SỞ LÝ THUYẾT
- THIẾT KẾ HỆ THỐNG
- TRIỂN KHAI
- KẾT QUẢ THỰC NGHIỆM
- KẾT LUẬN

BỐI CẢNH VÀ VẤN ĐỀ HIỆN NAY

Thực trạng:

- Tấn công mạng ngày càng tăng
- Doanh nghiệp cần bảo vệ tài nguyên nội bộ
- Việc đặt Web Server chung với mạng nội bộ làm tăng nguy cơ bị xâm nhập và đánh cắp dữ liệu.
- Các hành vi quét cổng (Port Scan), dò tìm dịch vụ và truy cập trái phép thường là bước đầu của một cuộc tấn công mạng.

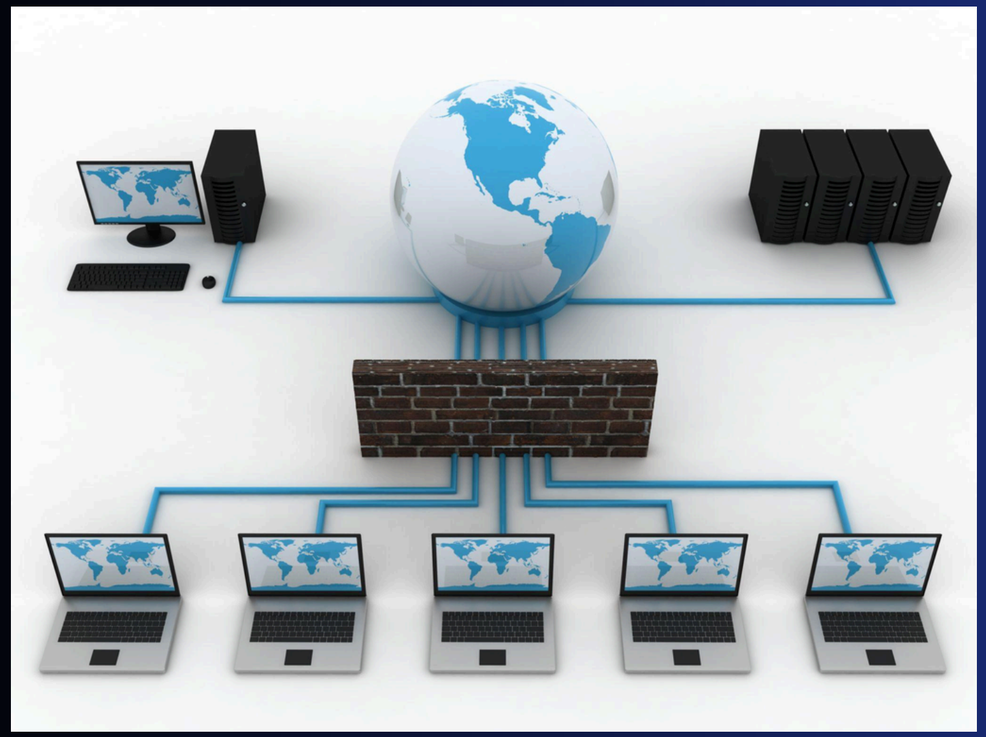
Mục tiêu:

- Xây dựng hệ thống mạng an toàn và các chính sách Firewall kiểm soát lưu lượng truy cập.
- Phân tách LAN và DMZ
- Triển khai Snort IDS/IPS để phát hiện và cảnh báo các hành vi tấn công mạng.
- Đánh giá hiệu quả hoạt động của hệ thống thông qua các kịch bản thực nghiệm.

MỤC TIÊU NGHIÊN CỨU

Mục tiêu tổng quát

Xây dựng và đánh giá hệ thống bảo mật mạng doanh nghiệp sử dụng pfSense nhằm nâng cao khả năng kiểm soát truy cập và giảm thiểu nguy cơ tấn công mạng.



Mục tiêu cụ thể

- Nghiên cứu cơ chế hoạt động của Firewall, NAT và vùng DMZ.
- Thiết kế mô hình mạng WAN – LAN – DMZ.
- Triển khai và cấu hình Firewall pfSense.
- Xây dựng chính sách Firewall và NAT Port Forward cho Web Server DMZ.
- Thực hiện các kịch bản kiểm thử bằng Nmap và Hydra.
- Đánh giá hiệu quả của Firewall kết hợp IDS/IPS (Snort, Suricata)

Cơ sở lý thuyết

CƠ SỞ LÝ THUYẾT

🔥 Firewall

- Lọc và kiểm soát gói tin
- Kiểm soát theo IP, Port, Protocol
- Ngăn truy cập trái phép
- Chính sách Default Deny

🛡️ pfSense

- Firewall mã nguồn mở
- Hỗ trợ NAT, VPN, VLAN
- Quản lý qua WebGUI
- Triển khai WAN-LAN-DMZ

🚨 IDS/IPS

- Hệ thống phát hiện xâm nhập
- Phát hiện Port Scan
- Phát hiện Brute-force SSH
- Cảnh báo và Block IP tự động

CÁC MỐI ĐE DỌA MẠNG

01

🔍 PORT SCANNING

- Dò tìm các cổng đang mở
- Thu thập thông tin dịch vụ
- Công cụ phổ biến: Nmap

02

🔐 BRUTE FORCE

- Thử nhiều tài khoản và mật khẩu
- Nhắm vào SSH, FTP, Web Login
- Mục tiêu: chiếm quyền truy cập

03

🌐 DoS / DDoS

- Gửi lượng lớn yêu cầu đến hệ thống
- Làm quá tải tài nguyên
- Gây gián đoạn dịch vụ

04

🦠 Khai thác lỗ hổng dịch vụ (Service Exploitation)

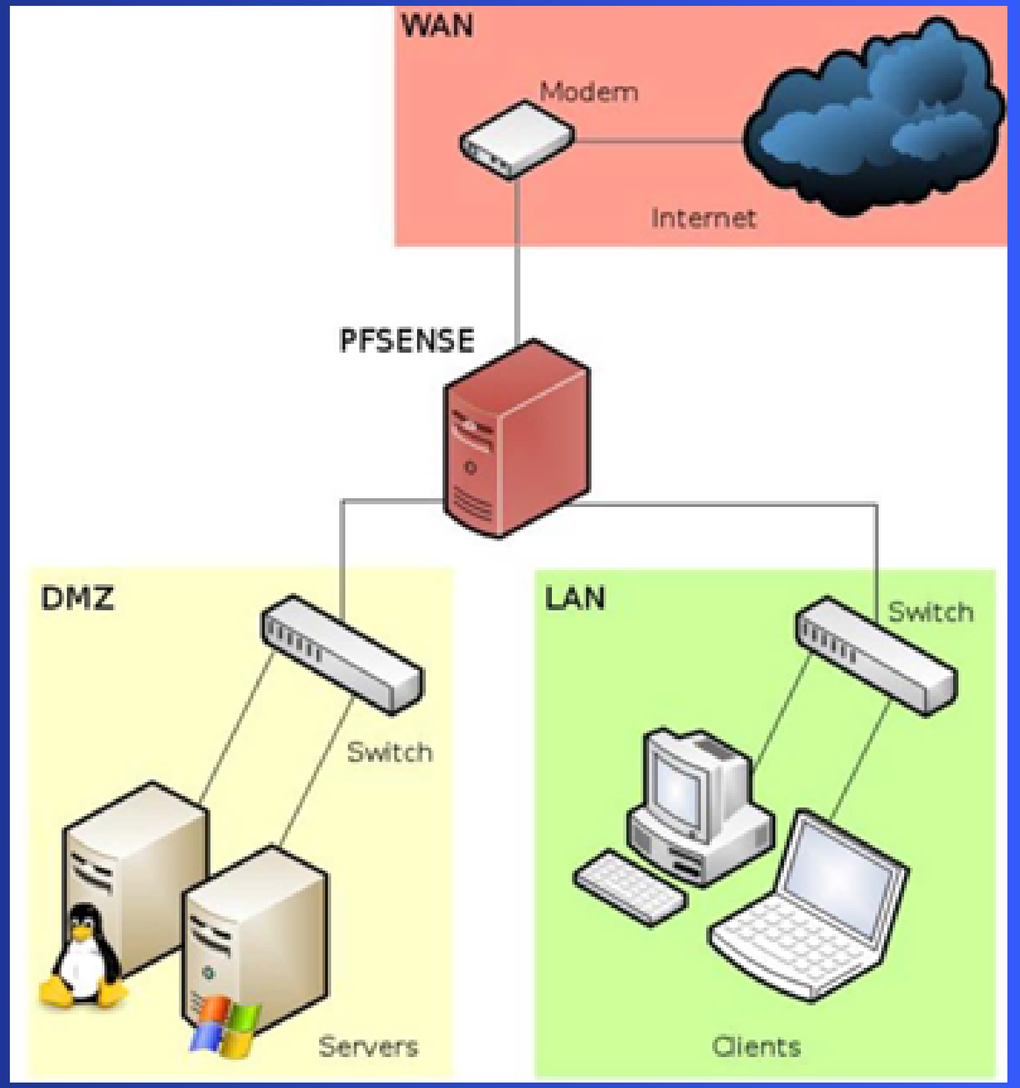
Là hình thức tấn công khai thác các lỗ hổng tồn tại trong hệ thống hoặc dịch vụ để truy cập trái phép hoặc thực thi mã độc.

THIẾT KẾ HỆ THỐNG

Mô hình hệ thống

- WAN: Kết nối với Internet.
- pfSense: Firewall trung tâm kiểm soát lưu lượng mạng.
- LAN: Mạng nội bộ dành cho người dùng.
- DMZ: Chứa Web Server cung cấp dịch vụ công khai.

=> pfSense kiểm soát toàn bộ lưu lượng giữa WAN, LAN và DMZ nhằm bảo vệ hệ thống khỏi truy cập trái phép.



CÔNG CỤ SỬ DỤNG

Môi trường thực nghiệm

VMware

pfsense

kali linux

ubuntu server

Công cụ kiểm thử & bảo mật

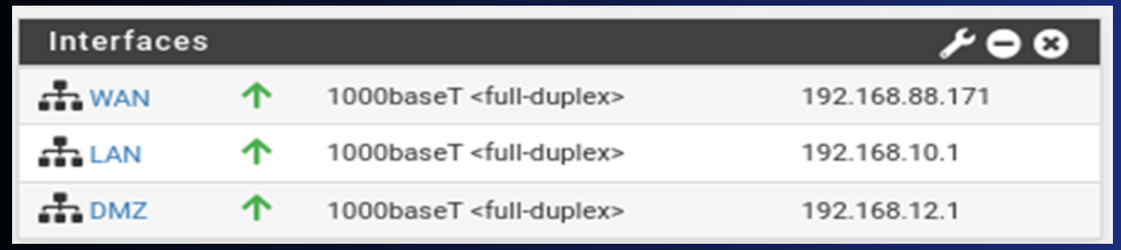
Nmap – Quét cổng hệ thống

hydra-brute force ssh

Snort – Phát hiện Port Scanning

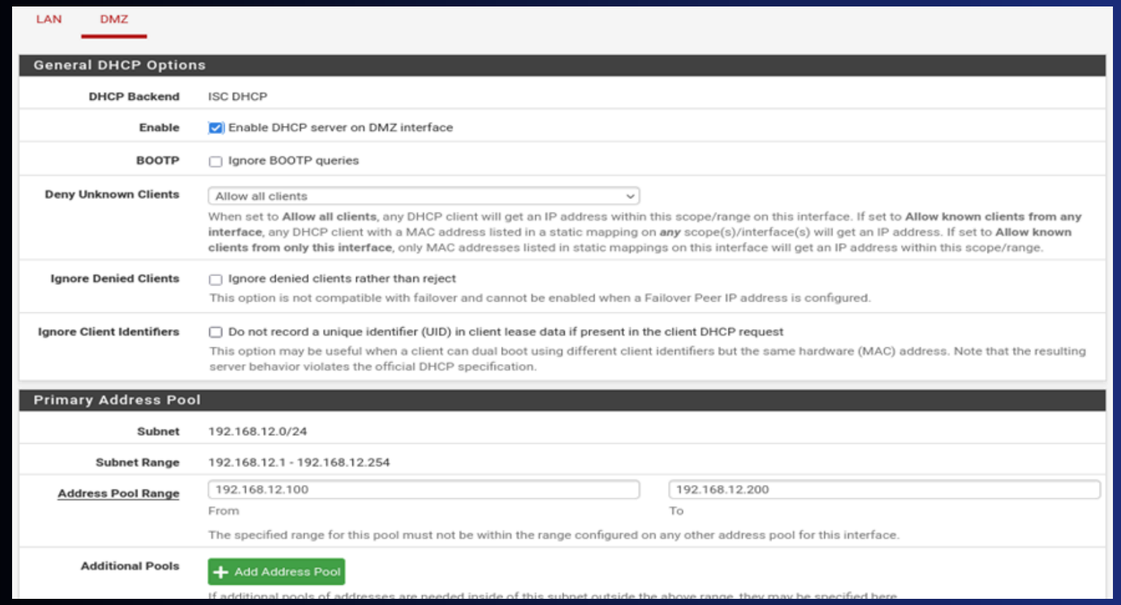
Suricata – Phát hiện Brute Force SSH

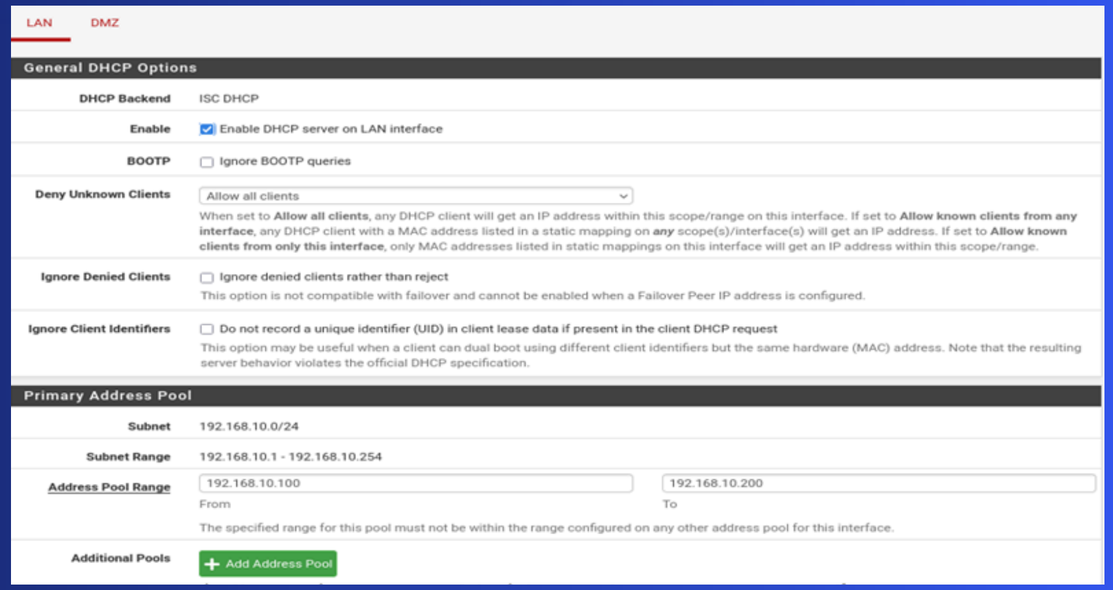
CẤU HÌNH MẠNG



INTERFACE WAN, LAN VÀ DMZ

- WAN: DHCP
- LAN: 192.168.10.1/24
- DMZ: 192.168.12.1/24





DHCP SERVER CHO LAN

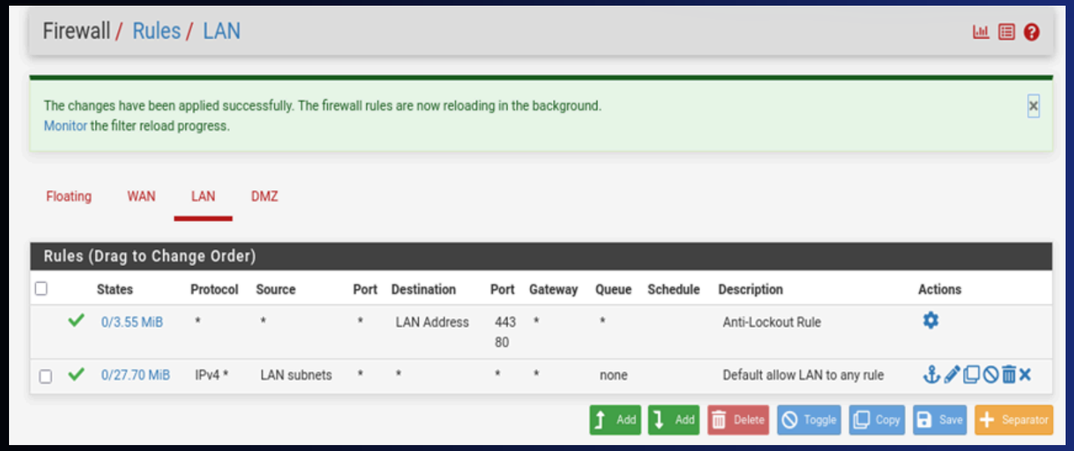
- GATEWAY: 192.168.10.1
- DẢI IP: 192.168.10.100 – 192.168.10.200

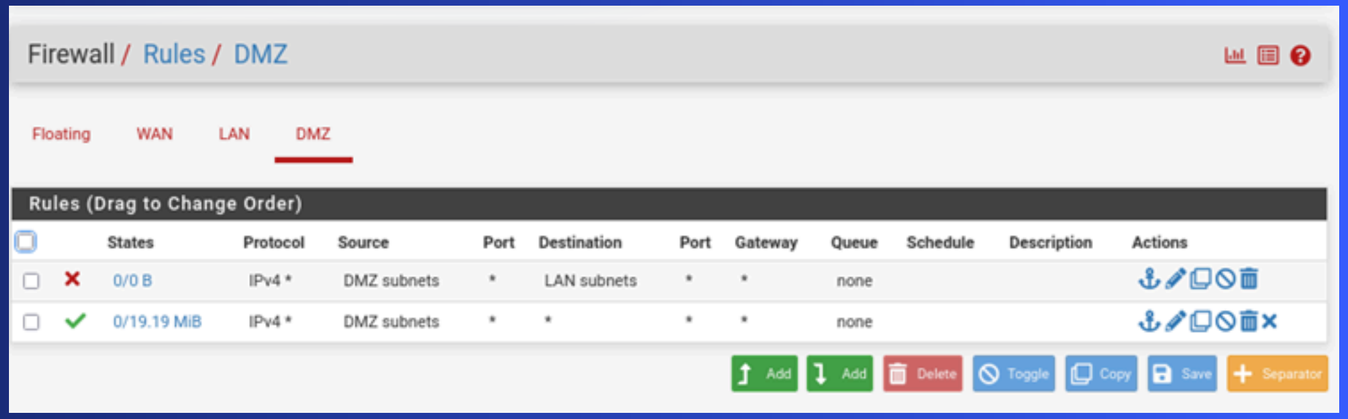
DHCP SERVER CHO DMZ:

- GATEWAY: 192.168.12.1
- DẢI IP: 192.168.12.100 – 192.168.12.200

Triển khai hệ thống

FIREWALL RULES





LAN firewall RULES :

- Cho phép LAN truy cập Internet
- Áp dụng chính sách Default Deny

DMZ firewall RULES:

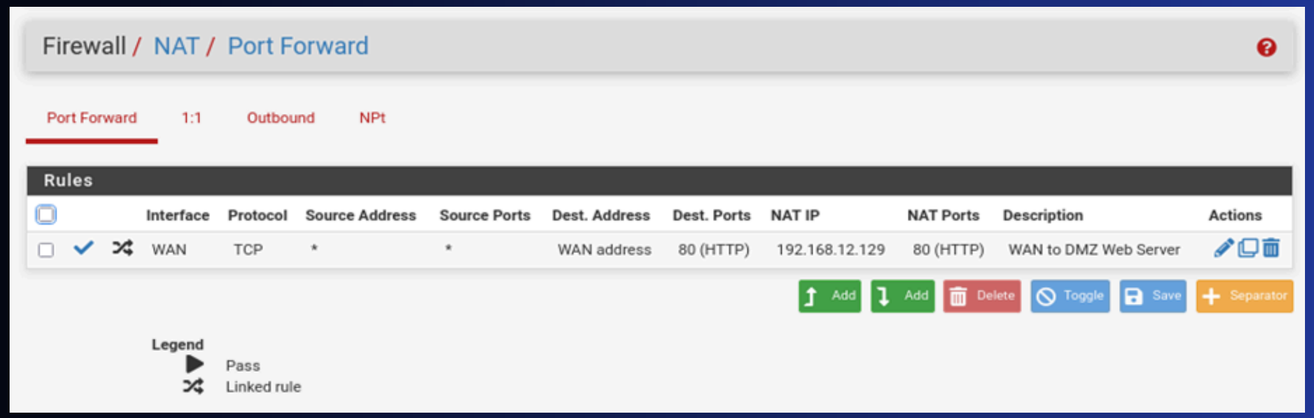
- Chặn truy cập từ dmz vào LAN
- Cho phép DMZ truy cập các dịch vụ cần thiết

FIREWALL RULES

WAN Firewall Rule:

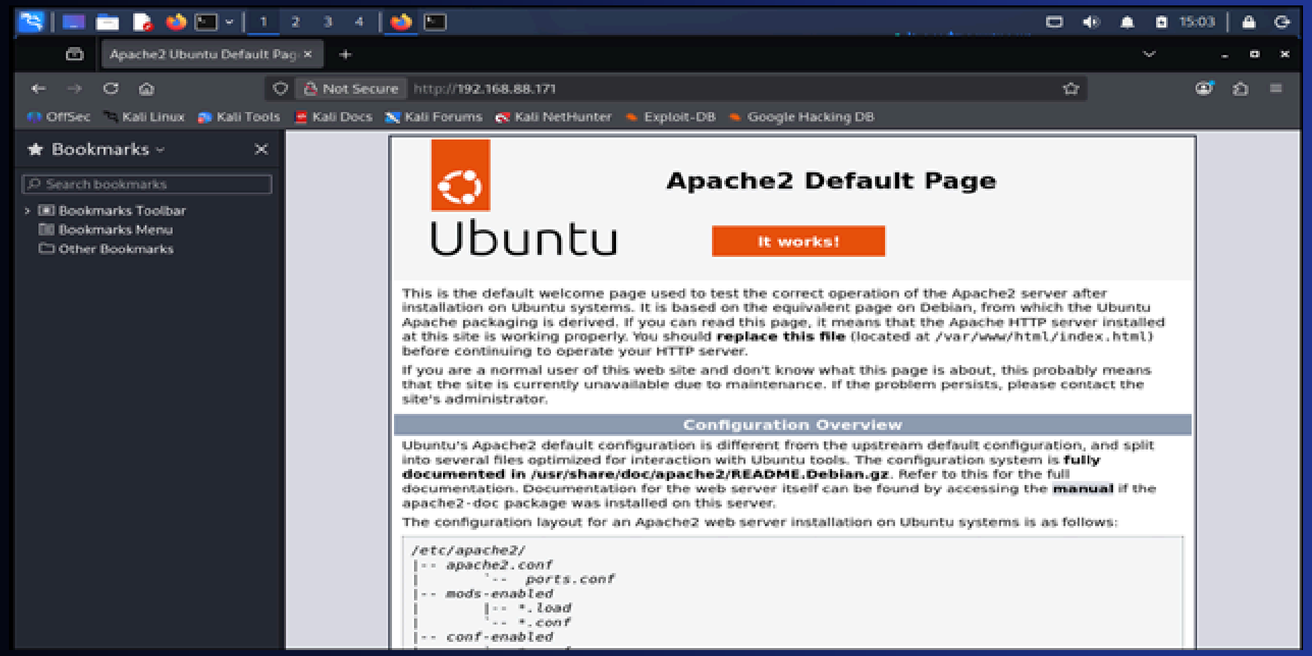
- Cho phép HTTP (Port 80) từ WAN
- Hỗ trợ NAT truy cập Web Server DMZ

NAT PORT FORWARD



NAT Port Forward:

- Chuyển tiếp cổng 80 từ WAN đến Web Server DMZ
- Cho phép truy cập Website từ Internet



Kiểm tra truy cập Web Server

- Truy cập Web Server thông qua địa chỉ WAN
- Nhận phản hồi Apache2 Ubuntu Default Page

Xác nhận NAT Port Forward hoạt động thành công

Kết quả thực nghiệm

KỊCH BẢN KIỂM THỬ

Hệ thống được kiểm thử với 2 kịch bản tấn công, thực hiện trong hai trường hợp:

- Tấn công từ mạng nội bộ (LAN → DMZ)
- Tấn công từ bên ngoài (WAN → DMZ/LAN)

Kịch bản 1: Port Scanning

- Công cụ: Nmap
- Mục tiêu: Phát hiện cổng và dịch vụ đang mở

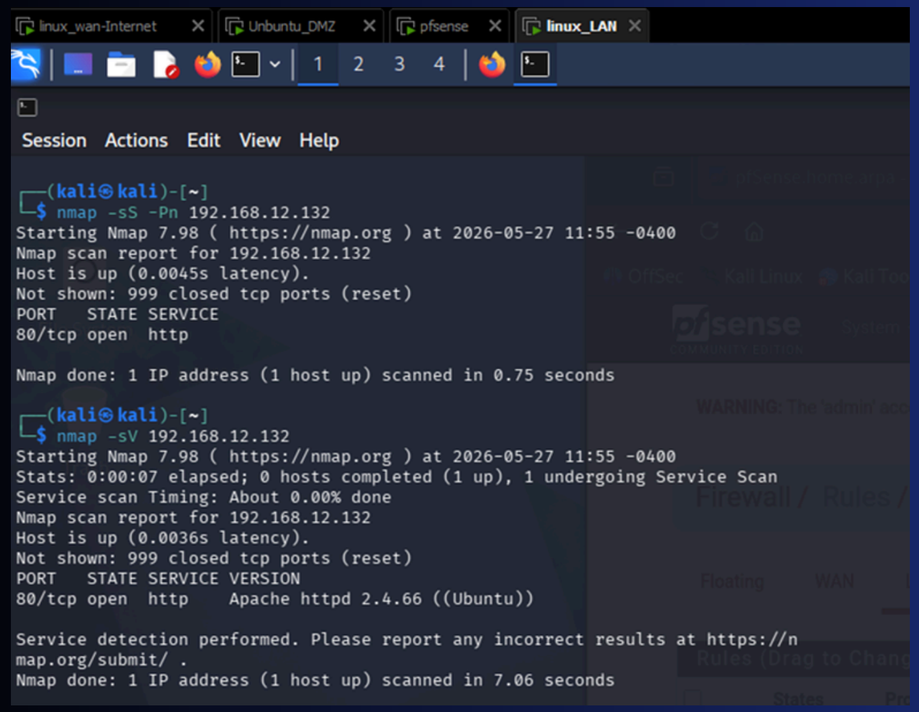
Kịch bản 2: Brute Force SSH

- Công cụ: Hydra
- Mục tiêu: Thử đăng nhập SSH bằng nhiều mật khẩu

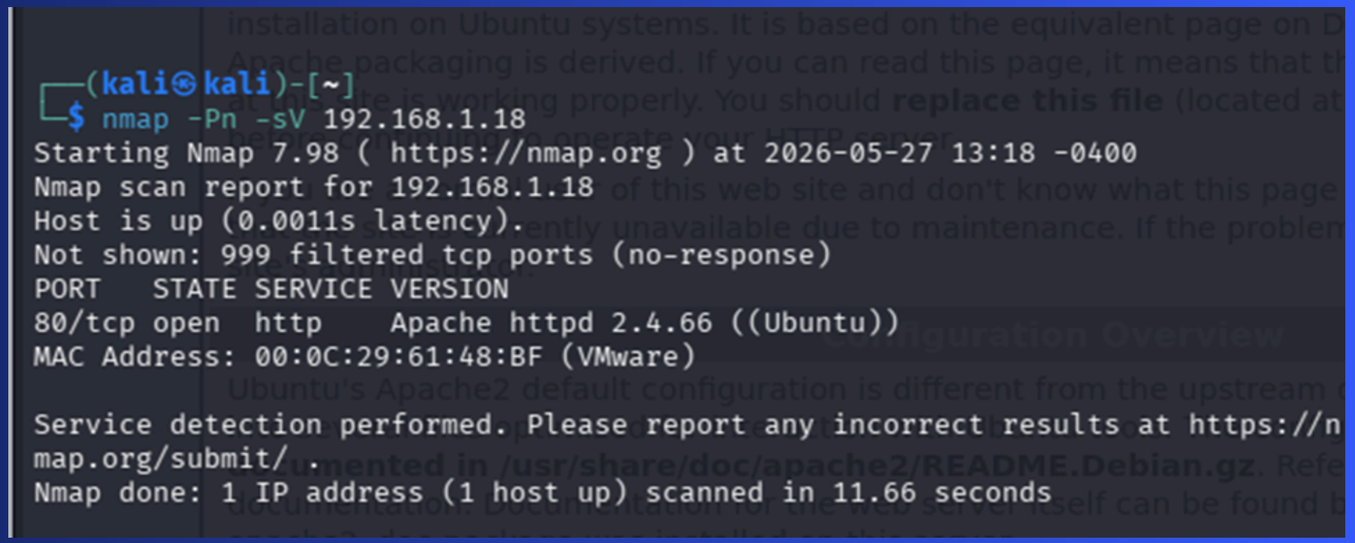
KẾT QUẢ PORT SCANNING TRƯỚC IDS/IPS

Công cụ kiểm thử: Nmap

Internal Attack (LAN → DMZ):

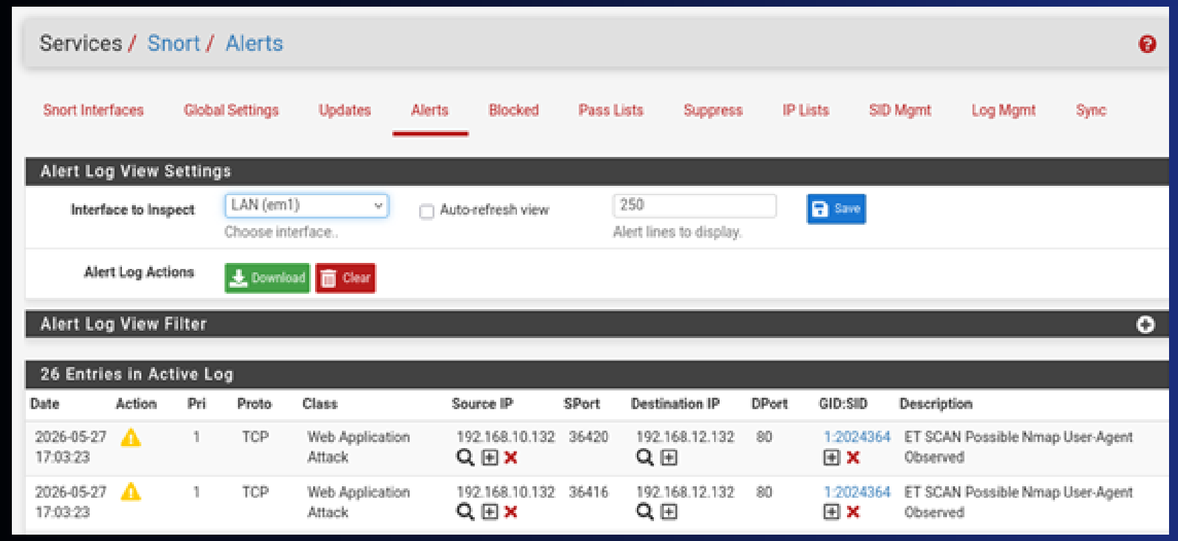


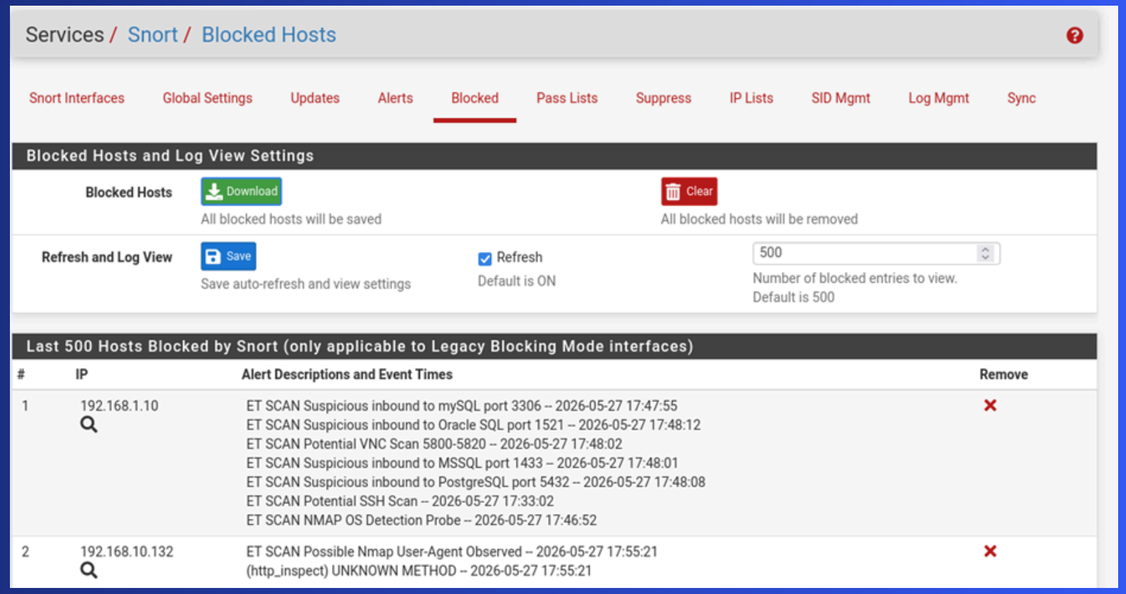
External Attack (WAN → DMZ):



=> Trước khi triển khai IDS/IPS, Nmap có thể quét cổng và thu thập thông tin dịch vụ trên Web Server từ cả mạng LAN và WAn

KẾT QUẢ PORT SCANNING SAU IDS/IPS





- Phát hiện hành vi Port Scanning
- Sinh cảnh báo IDS

- IP Attacker bị chặn
- Ngăn chặn quét cổng tiếp tục

=> Snort phát hiện thành công hành vi quét cổng Nmap và tự động chặn địa chỉ IP tấn công.

KẾT QUẢ BRUTE FORCE SSH TRƯỚC IDS/IPS

Công cụ: Hydra
Mục tiêu: SSH Server (DMZ)

Kết quả:

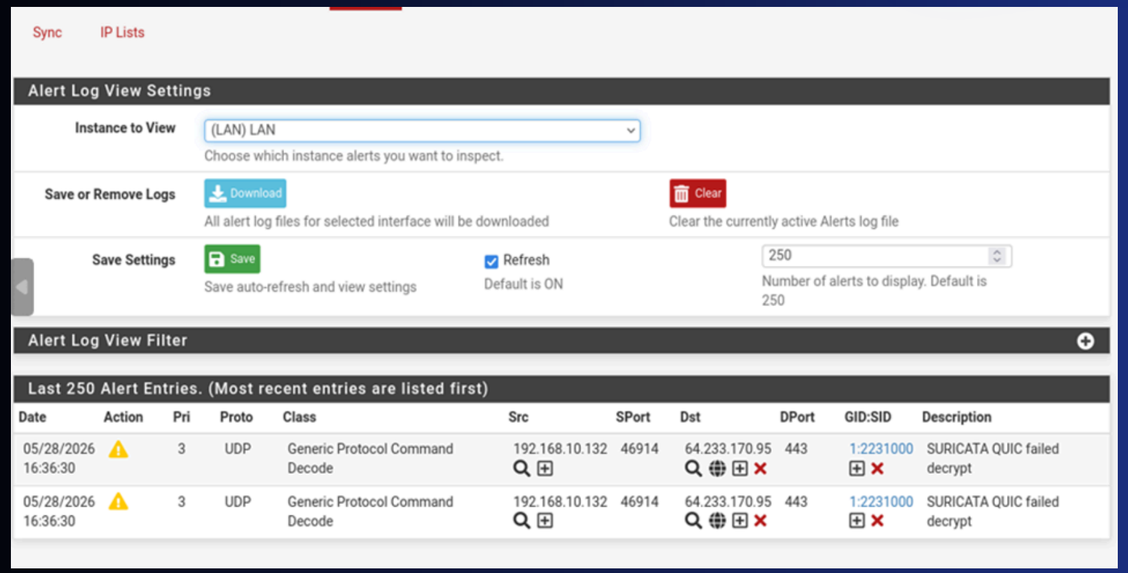
INTERNAL ATTACK (LAN → DMZ):

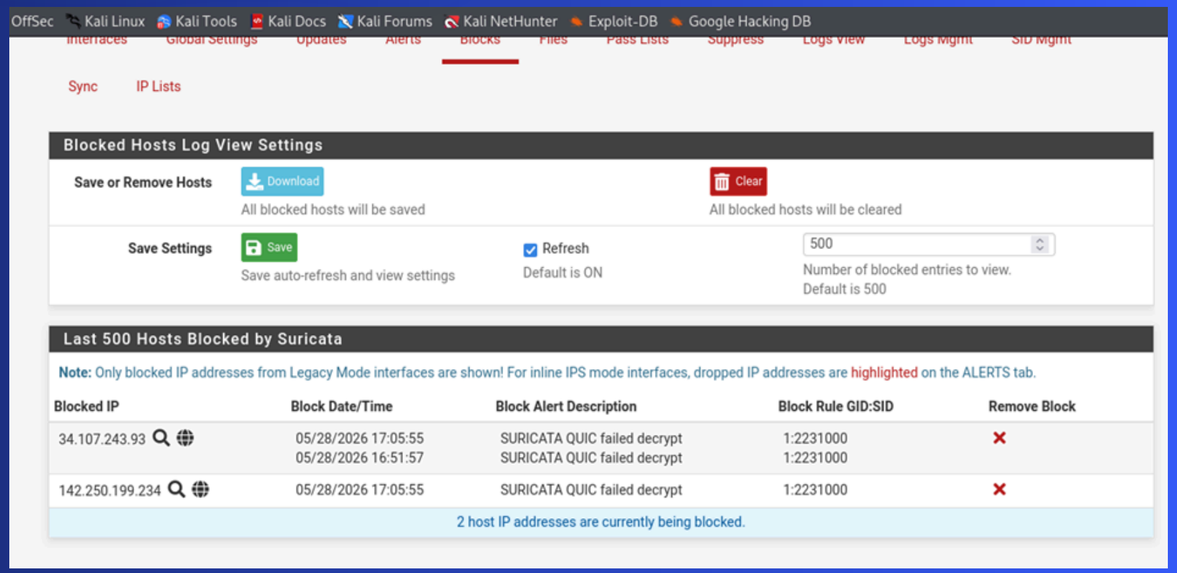
- Tìm được tài khoản hợp lệ
- Phát hiện mật khẩu: 123456
- Brute Force thành công

EXTERNAL ATTACK (WAN → DMZ):

- SSH (22) bị Firewall chặn
- Không thể thực hiện Brute Force
- Chỉ cho phép HTTP (80)

KẾT QUẢ SAU IDS/IPS (SURICATA)





Kết quả phát hiện:

- Suricata phát hiện lưu lượng bất thường
- Sinh cảnh báo an ninh mạng

Kết quả ngăn chặn:

- Suricata thực hiện cơ chế Block IP
- Các IP vi phạm được đưa vào danh sách chặn

=> Suricata phát hiện các lưu lượng bất thường trên mạng và thực hiện cơ chế chặn IP nhằm giảm thiểu nguy cơ truy cập trái phép.

HUTECH
Đại học Công nghệ Tp.HCM

BẢNG SO SÁNH

Kịch bản	Trước khi triển khai IDS/IPS	Sau khi triển khai IDS/IPS
Quét cổng từ LAN → DMZ	Attacker sử dụng Nmap phát hiện port 80 và dịch vụ Apache đang hoạt động trên Web Server DMZ	Snort IDS/IPS phát hiện hành vi quét cổng và tự động chặn IP attacker
Quét cổng từ WAN → DMZ	Attacker từ WAN phát hiện Web Server công khai qua cổng HTTP/80	Snort IDS/IPS phát hiện scan bất thường và đưa IP attacker vào danh sách chặn
Brute-force SSH từ LAN → DMZ	Hydra brute-force thành công tài khoản SSH do sử dụng mật khẩu yếu	Suricata IDS/IPS phát hiện lưu lượng bất thường và sinh cảnh báo trong quá trình brute-force SSH
Brute-force SSH từ WAN → DMZ	Attacker không thể truy cập SSH do firewall không NAT cổng 22	Firewall tiếp tục chặn truy cập SSH từ WAN, giảm nguy cơ brute-force từ Internet

KẾT LUẬN

ĐÁNH GIÁ HỆ THỐNG

Ưu điểm:

- Xây dựng thành công mô hình WAN – LAN – DMZ
- Firewall pfSense kiểm soát truy cập hiệu quả
- NAT Port Forward công bố Web Server an toàn
- Snort phát hiện hành vi Port Scanning
- Suricata hỗ trợ giám sát và chặn IP bất thường

Hạn chế:

- Mô hình thử nghiệm quy mô nhỏ
- Chưa triển khai VPN và VLAN
- Chưa đánh giá các kịch bản DDoS quy mô lớn
- Chưa tích hợp hệ thống SIEM tập trung

HUTECH
Đại học Công nghệ Tp.HCM

KẾT LUẬN

- Xây dựng thành công mô hình mạng WAN – LAN – DMZ sử dụng Firewall pfSense.
- Triển khai các chức năng bảo mật gồm Firewall Rules, NAT Port Forwarding và DHCP Server.
- Thực hiện kiểm thử bằng Nmap và Hydra để đánh giá mức độ an toàn của hệ thống.
- Nâng cao khả năng phát hiện và ngăn chặn tấn công thông qua Snort và Suricata.

Hệ thống đáp ứng mục tiêu đề ra trong việc kiểm soát truy cập, bảo vệ mạng nội bộ và tăng cường khả năng giám sát an ninh mạng.

HƯỚNG PHÁT TRIỂN

- Triển khai VPN để hỗ trợ truy cập từ xa an toàn.
- Áp dụng VLAN nhằm phân tách và quản lý mạng hiệu quả hơn.
- Tích hợp SIEM để giám sát và phân tích sự kiện an ninh tập trung.
- Nghiên cứu và đánh giá khả năng phòng chống tấn công DDoS.
- Triển khai trên môi trường doanh nghiệp thực tế với quy mô lớn hơn.

HUTECH
Đại học Công nghệ Tp.HCM

XIN CẢM ƠN QUÝ THẦY/ CÔ ĐÃ LẮNG NGHE!